# Agenten-Zugriffsregeln

## Wie KI-Agenten von MALELU auf Konten, Postfächer und Systeme zugreifen – und wie nie

Stand 30.10.2026 · Version 1.0

**Für Kundinnen und Kunden von KOMPΛGNON und Claimly · Stand 30.10.2026 · Version 1.0**

### Warum dieses Blatt

Im Oktober 2026 haben mehrere Großbanken begonnen, KI-Agenten auszusperren, die sich mit den Zugangsdaten ihrer Kundinnen und Kunden einloggen und teils ohne Rückfrage Überweisungen auslösen (Quelle: Axios / The Neuron, Oktober 2026). Das ist kein Bank-Problem, sondern ein Design-Fehler: Ein Agent, der Ihr Passwort kennt, ist von Ihnen nicht zu unterscheiden. Bei MALELU gilt deshalb seit dem ersten Agenten eine einfache Regel: **Ein Agent bekommt nie Ihr Login. Er bekommt seinen eigenen.**

### Die sechs Regeln

1. **Eigenes Konto statt Ihr Konto.** Jeder Agent arbeitet mit einem eigenen Service-Konto (z. B. `agent@ihrbetrieb.at`), das Sie jederzeit sehen, einschränken und abschalten können. Ihr persönliches Passwort geben Sie nie weiter – auch nicht an uns.
2. **OAuth statt Passwort.** Zugriff auf Google, Microsoft, Buchhaltung oder Bank-Schnittstellen läuft über OAuth-Freigaben oder API-Schlüssel, die Sie in Ihrem Konto erteilen und widerrufen. Kein gespeichertes Passwort, kein Bildschirm-Mitlesen, kein Browser-Login in Ihrem Namen.
3. **So wenig Rechte wie möglich.** Der Agent erhält nur die Berechtigungen (Scopes), die seine Aufgabe braucht: Lesen, wenn Lesen reicht; Entwürfe statt Versand; nie „Vollzugriff“. Jede Erweiterung wird schriftlich begründet und von Ihnen freigegeben.
4. **Jede Aktion im Protokoll.** Was der Agent gelesen, geschrieben oder gesendet hat, steht mit Zeitstempel, Ziel und Ergebnis im Audit-Log. Sie können es jederzeit einsehen und exportieren.
5. **Freigabe an jedem Gate.** Geld bewegen, Verträge annehmen, Daten löschen, nach außen senden: Das macht der Agent nicht allein. Er bereitet vor, Sie geben frei. Vollautomatik ist kein Ziel – die Freigabe schon.
6. **Schlüssel werden gewechselt und entzogen.** Zugangsschlüssel haben ein Ablaufdatum, werden rotiert und beim Ende der Zusammenarbeit widerrufen. Wir behalten keine Zugänge „für den Fall“.

### Was wir nie tun

- Mit Ihrem Online-Banking-Login arbeiten. Zahlungen laufen ausschließlich über Ihre Freigabe oder über offizielle Bank-Schnittstellen mit eigenem Mandat.

- Passwörter, TAN-Verfahren oder Zwei-Faktor-Codes entgegennehmen, speichern oder weiterleiten.
- Zugangsdaten zwischen Kunden, Systemen oder Agenten teilen.
- Sicherheitsabfragen, Bot-Sperren oder Nutzungsbedingungen eines Dienstes umgehen.
- Ohne Protokoll handeln.

## Ihre Checkliste vor dem Start

| Schritt | Erledigt |
|---|---|
| Service-Konto für den Agenten angelegt (eigene Adresse, eigenes Passwort, 2FA aktiv) | ☐ |
| Zugriffe per OAuth/API-Schlüssel erteilt – keine Passwortweitergabe | ☐ |
| Berechtigungen auf die Aufgabe beschränkt (Lesen/Entwurf/Senden einzeln geprüft) | ☐ |
| Freigabe-Gates festgelegt (welche Aktionen brauchen Ihr Ja?) | ☐ |
| Zugang zum Audit-Log eingerichtet | ☐ |
| Notaus bekannt: Wo schalten Sie den Agenten in unter einer Minute ab? | ☐ |

## Warum das für Sie zählt

Banken-Nutzungsbedingungen untersagen in der Regel die Weitergabe von Zugangsdaten an Dritte – auch an Software. Wer einem Agenten das eigene Login gibt, riskiert gesperrte Konten und im Schadensfall Diskussionen über die Haftung. Mit eigenem Konto, begrenzten Rechten und lückenlosem Protokoll bleibt die Verantwortung dort, wo sie hingehört: bei Ihnen als Freigebende, bei uns als Betreiber, beim Agenten als dokumentiertem Werkzeug.